

AI - SPEECH

Mon, 17 Aug 2026 18:09:11 IST

TABLE OF CONTENTS

Vulnerabilities by Plugin

- 98056 (4) - Missing HTTP Strict Transport Security Policy
- 98983 (1) - Insecure Cross-Origin Resource Sharing Configuration
- 113258 (1) - OpenAPI Permissive Input Validation
- 98060 (2) - Missing 'X-Frame-Options' Header
- 112529 (2) - Missing 'X-Content-Type-Options' Header
- 112553 (2) - Missing 'Cache-Control' Header
- 98057 (1) - Insecure 'Access-Control-Allow-Origin' Header
- 98081 (1) - Password Field With Auto-Complete
- 112539 (1) - SSL/TLS Weak Cipher Suites Supported
- 112551 (1) - Missing Content Security Policy
- 113332 (1) - Login Form Cross-Site Request Forgery
- 98618 (4) - HTTP Header Information Disclosure
- 98050 (3) - Interesting Response
- 98148 (2) - Form Detected
- 98526 (2) - Missing Permissions Policy
- 98527 (2) - Missing Referrer Policy
- 98000 (1) - Scan Information
- 98009 (1) - Web Application Sitemap
- 98047 (1) - Allowed HTTP Methods
- 98059 (1) - Technologies Detected
- 98136 (1) - Target Information
- 98138 (1) - Screenshot
- 98772 (1) - Fetch/XHR Detected
- 112491 (1) - SSL/TLS Certificate Information
- 112530 (1) - SSL/TLS Versions Supported
- 112598 (1) - SSL/TLS Server Cipher Suite Preference
- 112613 (1) - Allowed HTTP Versions
- 112615 (1) - OpenAPI File Detected
- 112616 (1) - API Detected
- 112723 (1) - Security.txt File Not Detected
- 113045 (1) - SSL/TLS Certificate Contains Wildcard Entries
- 113393 (1) - Performance Telemetry
- 115491 (1) - SSL/TLS Cipher Suites Supported
- 172036 (1) - Web Application Scanner

98056 (4) - Missing HTTP Strict Transport Security Policy

Synopsis

Missing HTTP Strict Transport Security Policy

Description

The HTTP protocol by itself is clear text, meaning that any data that is transmitted via HTTP can be captured and the contents viewed. To keep data private and prevent it from being intercepted, HTTP is often tunnelled through either Secure Sockets Layer (SSL) or Transport Layer Security (TLS). When either of these encryption standards are used, it is referred to as HTTPS.

HTTP Strict Transport Security (HSTS) is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. This will be enforced by the browser even if the user requests a HTTP resource on the same server.

Cyber-criminals will often attempt to compromise sensitive information passed from the client to the server using HTTP. This can be conducted via various Man-in-The-Middle (MiTM) attacks or through network packet captures.

Scanner discovered that the affected application is using HTTPS however does not use the HSTS header.

See Also

- <https://tools.ietf.org/html/rfc6797>
- https://www.owasp.org/index.php/HTTP_Strict_Transport_Security_Cheat_Sheet
- <https://www.chromium.org/hsts>
- <https://hstspreload.org/>

Solution

Depending on the framework being used the implementation methods will vary, however it is advised that the 'Strict-Transport-Security' header be configured on the server.
One of the options for this header is 'max-age', which is a representation (in milliseconds) determining the time in which the client's browser will adhere to the header policy.
Depending on the environment and the application this time period could be from as low as minutes to as long as days.

Risk Factor

Medium

CVSS v4.0 Base Score

6.3 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

6.5 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N)

CVSS v2.0 Base Score

5.8 (CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:N)

References

XREF	CWE:319
XREF	CWE:523
XREF	WASC:Insufficient Transport Layer Protection
XREF	HIPAA:164.312(a)
XREF	HIPAA:164.312(e)
XREF	CAPEC:102
XREF	CAPEC:117
XREF	CAPEC:383
XREF	CAPEC:477
XREF	CAPEC:65
XREF	DISA_STIG:APSC-DV-000170
XREF	DISA_STIG:APSC-DV-001750
XREF	OWASP:2010-A9
XREF	OWASP:2013-A6

XREF	OWASP:2017-A3
XREF	OWASP:2021-A2
XREF	OWASP:2025-A4
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-9.1.1
XREF	PCI_DSS:3.2-6.5.4
XREF	ISO:27001-A.10.1.1
XREF	ISO:27001-A.14.1.2
XREF	ISO:27001-A.14.1.3
XREF	ISO:27001-A.18.1.5
XREF	NIST:sp800_53-IA-5(1)
XREF	NIST:sp800_53-SC-13

Plugin Information

Published: 2017/03/31, Modified: 2025/05/16

Instances

https://ai.rcilab.in:8000/ (tcp/8000)

URL

```
https://ai.rcilab.in:8000/authenticate
```

OUTPUT

```
The scanner did not find any Strict-Transport-Security header in the response returned by the target when querying URL 'https://ai.rcilab.in:8000/authenticate'.
```

REQUEST MADE

```
POST /authenticate
```

REQUEST HEADERS

```
Content-Type: application/x-www-form-urlencoded
Origin: https://ai.rcilab.in:8000
Referer: https://ai.rcilab.in:8000/login
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Sec-Ch-Ua: "Chromium";v="149", "Not)A;Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 303 See Other
date: Mon, 17 Aug 2026 07:00:00 GMT
server: uvicorn
content-length: 0
location: /login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials
access-control-allow-origin: *
access-control-allow-credentials: true
```

https://ai.rcilab.in:8000/ (tcp/8000)

URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
The scanner did not find any Strict-Transport-Security header in the response returned by the target when querying URL 'https://ai.rcilab.in:8000/'.
```

REQUEST MADE

```
GET / HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 303 See Other
date: Mon, 17 Aug 2026 06:52:36 GMT
server: uvicorn
content-length: 0
location: /login
```

https://ai.rcilab.in:8000/ (tcp/8000)

URL

```
https://ai.rcilab.in:8000/login
```

OUTPUT

```
The scanner did not find any Strict-Transport-Security header in the response returned by the target when querying URL
'https://ai.rcilab.in:8000/login'.
```

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

https://ai.rcilab.in:8000/ (tcp/8000)

URL

```
https://ai.rcilab.in:8000/was_404_check
```

OUTPUT

```
The scanner did not find any Strict-Transport-Security header in the response returned by the target when querying URL
'https://ai.rcilab.in:8000/was_404_check'.
```

REQUEST MADE

```
GET /was_404_check HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json
```

98983 (1) - Insecure Cross-Origin Resource Sharing Configuration

Synopsis

Insecure Cross-Origin Resource Sharing Configuration

Description

Cross Origin Resource Sharing (CORS) is an HTML5 technology which gives modern web browsers the ability to bypass restrictions implemented by the Same Origin Policy.

The Same Origin Policy requires that both the JavaScript and the page are loaded from the same domain in order to allow JavaScript to interact with the page. This in turn prevents malicious JavaScript being executed when loaded from external domains.

The CORS policy allows the application to specify exceptions to the protections implemented by the browser, and enables the developer to specify allowlisted for which external JavaScript is permitted to execute and interact with the page.

An insecure CORS configuration allows any website to trigger requests with user credentials to the target application and read the responses, thus enabling attackers to perform privileged actions or to retrieve potential sensitive information.

See Also

<https://www.w3.org/TR/cors/#security>
https://developer.mozilla.org/en-US/docs/Web/HTTP/Access_control_CORS

Solution

The application should be configured with an allowlist including only specific and trusted domains to perform CORS requests.

Risk Factor

Medium

CVSS v4.0 Base Score

5.1 (CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:L/VI:L/VA:N/SC:L/SI:L/SA:N)

CVSS v3.0 Base Score

6.1 (CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

XREF	CWE:346
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)

XREF	CAPEC:111
XREF	CAPEC:141
XREF	CAPEC:142
XREF	CAPEC:160
XREF	CAPEC:21
XREF	CAPEC:384
XREF	CAPEC:385
XREF	CAPEC:386
XREF	CAPEC:387
XREF	CAPEC:388
XREF	CAPEC:510
XREF	CAPEC:59
XREF	CAPEC:60
XREF	CAPEC:75
XREF	CAPEC:76
XREF	CAPEC:89
XREF	DISA_STIG:APSC-DV-002560
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A7
XREF	OWASP:2025-A7
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-14.4.7
XREF	PCI_DSS:3.2-6.5.8
XREF	ISO:27001-A.10.1
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-SI-10(5)

Plugin Information

Published: 2020/03/06, Modified: 2021/11/26

Instances

https://ai.rcilab.in:8000/ (tcp/8000)

URL

https://ai.rcilab.in:8000/authenticate

PAYLOAD

N/A

PROOF

```
{"Access-Control-Allow-Credentials"=>"true", "Access-Control-Allow-Origin"=>"*", "Content-Length"=>"0", "Date"=>"Mon, 17 Aug 2026 07:00:00 GMT", "Location"=>"/login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials", "Server"=>"uvicorn"}
```

OUTPUT

The scanner has detected an insecure CORS configuration on the target application : Access-Control-Allow-Origin is set to * and Access-Control-Allow-Credentials is set to true. This configuration allows any domain to perform cross-domains requests with user credentials and access the responses.

Access-Control-Allow-Origin header should be set to allow only known and trusted domains to issue CORS requests.

REQUEST MADE

POST /authenticate

REQUEST HEADERS

Content-Type: application/x-www-form-urlencoded
Origin: https://ai.rcilab.in:8000
Referer: https://ai.rcilab.in:8000/login
Sec-Fetch-Dest: empty

```
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Sec-Ch-Ua: "Chromium";v="149", "Not)A;Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 303 See Other
date: Mon, 17 Aug 2026 07:00:00 GMT
server: uvicorn
content-length: 0
location: /login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials
access-control-allow-origin: *
access-control-allow-credentials: true
```

113258 (1) - OpenAPI Permissive Input Validation

Synopsis

OpenAPI Permissive Input Validation

Description

OpenAPI specification is an API description format for REST APIs. An OpenAPI file is written in YAML or JSON and describes all the API properties like the available endpoints with the related operations or the authentication methods.

The 'Schema' object allows the definition of input and output data types which can be objects or primitives and arrays. When some data types properties are missing on objects specified in the definition file, the API implementation could potentially allow malicious input formats, leaving it open to multiple vulnerabilities like Denial of Service (DoS) or Remote Code Execution (RCE).

The scanner analyzed an OpenAPI definition file and detected the lack of properties on some data types.

See Also

<https://github.com/OAI/OpenAPI-Specification/blob/main/versions/3.0.2.md#schemaObject>

Solution

Ensure that the missing properties are declared in the OpenAPI definition file according to the file specification and that the API backend enforces the validation of these properties on the inputs.

Risk Factor

Medium

CVSS v4.0 Base Score

6.3 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

5.6 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:L)

CVSS v2.0 Base Score

6.8 (CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:P)

References

XREF	CWE:20
XREF	WASC:Improper Input Handling
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:10
XREF	CAPEC:101
XREF	CAPEC:104
XREF	CAPEC:108
XREF	CAPEC:109
XREF	CAPEC:110
XREF	CAPEC:120

XREF	CAPEC:13
XREF	CAPEC:135
XREF	CAPEC:136
XREF	CAPEC:14
XREF	CAPEC:153
XREF	CAPEC:182
XREF	CAPEC:209
XREF	CAPEC:22
XREF	CAPEC:23
XREF	CAPEC:230
XREF	CAPEC:231
XREF	CAPEC:24
XREF	CAPEC:250
XREF	CAPEC:261
XREF	CAPEC:267
XREF	CAPEC:28
XREF	CAPEC:3
XREF	CAPEC:31
XREF	CAPEC:42
XREF	CAPEC:43
XREF	CAPEC:45
XREF	CAPEC:46
XREF	CAPEC:47
XREF	CAPEC:473
XREF	CAPEC:52
XREF	CAPEC:53
XREF	CAPEC:588
XREF	CAPEC:63
XREF	CAPEC:64
XREF	CAPEC:67
XREF	CAPEC:7
XREF	CAPEC:71
XREF	CAPEC:72
XREF	CAPEC:73
XREF	CAPEC:78
XREF	CAPEC:79
XREF	CAPEC:8
XREF	CAPEC:80
XREF	CAPEC:81
XREF	CAPEC:83
XREF	CAPEC:85
XREF	CAPEC:88
XREF	CAPEC:9
XREF	DISA_STIG:APSC-DV-002560
XREF	OWASP:2010-A4
XREF	OWASP:2013-A4
XREF	OWASP:2017-A5
XREF	OWASP:2021-A3
XREF	OWASP:2025-A5
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-5.1.3
XREF	PCI_DSS:3.2-6.5
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-SI-10

Plugin Information

Published: 2022/06/28, Modified: 2025/07/28

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/openapi.json
```

OUTPUT

The scanner detected the presence of permissive input(s) in the API host(s) used in the detected OpenAPI file on the following URL
https://ai.rcilab.in:8000/openapi.json.

The following operations have parameter with permissive inputs :

- Operation 'get' on path '/job_status/{job_id}' have parameter 'job_id' (String) without the 'format' property declared
- Operation 'get' on path '/job_status/{job_id}' have parameter 'job_id' (String) without the 'maxLength' property declared
- Operation 'get' on path '/job_status/{job_id}' have parameter 'job_id' (String) without the 'pattern' property declared
- Operation 'get' on path '/task_sessions/{task_id}' have parameter 'task_id' (String) without the 'format' property declared
- Operation 'get' on path '/task_sessions/{task_id}' have parameter 'task_id' (String) without the 'maxLength' property declared
- Operation 'get' on path '/task_sessions/{task_id}' have parameter 'task_id' (String) without the 'pattern' property declared
- Operation 'get' on path '/discussion_session/{session_id}' have parameter 'session_id' (String) without the 'format' property declared
- Operation 'get' on path '/discussion_session/{session_id}' have parameter 'session_id' (String) without the 'maxLength' property declared
- Operation 'get' on path '/discussion_session/{session_id}' have parameter 'session_id' (String) without the 'pattern' property declared
- Operation 'get' on path '/check_global_summary/{session_id}' have parameter 'session_id' (String) without the 'format' property declared
- Operation 'get' on path '/check_global_summary/{session_id}' have parameter 'session_id' (String) without the 'maxLength' property declared
- Operation 'get' on path '/check_global_summary/{session_id}' have parameter 'session_id' (String) without the 'pattern' property declared
- Operation 'get' on path '/get_global_summary/{session_id}' have parameter 'session_id' (String) without the 'format' property declared
- Operation 'get' on path '/get_global_summary/{session_id}' have parameter 'session_id' (String) without the 'maxLength' property declared
- Operation 'get' on path '/get_global_summary/{session_id}' have parameter 'session_id' (String) without the 'pattern' property declared

The following components have parameter with permissive inputs :

- Component 'Body_authenticate_authenticate_post' has parameter 'username' (String) without the 'format' property declared
- Component 'Body_authenticate_authenticate_post' has parameter 'username' (String) without the 'maxLength' property declared
- Component 'Body_authenticate_authenticate_post' has parameter 'username' (String) without the 'pattern' property declared
- Component 'Body_authenticate_authenticate_post' has parameter 'password' (String) without the 'format' property declared
- Component 'Body_authenticate_authenticate_post' has parameter 'password' (String) without the 'maxLength' property declared
- Component 'Body_authenticate_authenticate_post' has parameter 'password' (String) without the 'pattern' property declared
- Component 'Body_log_dictation_endpoint_log_dictation_post' has parameter 'duration' (Number) without the 'format' property declared
- Component 'Body_log_dictation_endpoint_log_dictation_post' has parameter 'duration' (Number) without the 'maximum' property declared
- Component 'Body_log_dictation_endpoint_log_dictation_post' has parameter 'duration' (Number) without the 'minimum' property declared
- Component 'Body_log_dictation_endpoint_log_dictation_post' has parameter 'result' (String) without the 'format' property declared
- Component 'Body_log_dictation_endpoint_log_dictation_post' has parameter 'result' (String) without the 'maxLength' property declared
- Component 'Body_log_dictation_endpoint_log_dictation_post' has parameter 'result' (String) without the 'pattern' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'file' (String) without the 'maxLength' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'file' (String) without the 'pattern' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'mode' (String) without the 'format' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'mode' (String) without the 'maxLength' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'mode' (String) without the 'pattern' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'summary_length' (String) without the 'format' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'summary_length' (String) without the 'maxLength' property declared
- Component 'Body_process_audio_process_audio_post' has parameter 'summary_length' (String) without the 'pattern' property declared
- Component 'GlobalSummaryRequest' has parameter 'texts' (Array) without the 'maxItems' property declared
- Component 'HTTPValidationError' has parameter 'detail' (Array) without the 'maxItems' property declared

- Component 'ValidationError' has parameter 'loc' (Array) without the 'maxItems' property declared
- Component 'ValidationError' has parameter 'msg' (String) without the 'format' property declared
- Component 'ValidationError' has parameter 'msg' (String) without the 'maxLength' property declared
- Component 'ValidationError' has parameter 'msg' (String) without the 'pattern' property declared
- Component 'ValidationError' has parameter 'type' (String) without the 'format' property declared
- Component 'ValidationError' has parameter 'type' (String) without the 'maxLength' property declared
- Component 'ValidationError' has parameter 'type' (String) without the 'pattern' property declared

98060 (2) - Missing 'X-Frame-Options' Header

Synopsis

Missing 'X-Frame-Options' Header

Description

Clickjacking (User Interface redress attack, UI redress attack, UI redressing) is a malicious technique of tricking a Web user into clicking on something different from what the user perceives they are clicking on, thus potentially revealing confidential information or taking control of their computer while clicking on seemingly innocuous web pages.

The server didn't return an `X-Frame-Options` header which means that this website could be at risk of a clickjacking attack.

The `X-Frame-Options` HTTP response header can be used to indicate whether or not a browser should be allowed to render a page inside a frame or iframe. Sites can use this to avoid clickjacking attacks, by ensuring that their content is not embedded into other sites.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/X-Frame-Options>
<http://tools.ietf.org/html/rfc7034>
<https://www.owasp.org/index.php/Clickjacking>

Solution

Configure your web server to include an `X-Frame-Options` header.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:L/SI:L/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:L/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:N/I:P/A:N)

References

XREF	CWE:1021
XREF	CWE:346
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:103
XREF	CAPEC:111
XREF	CAPEC:141
XREF	CAPEC:142
XREF	CAPEC:160
XREF	CAPEC:181
XREF	CAPEC:21
XREF	CAPEC:222
XREF	CAPEC:384
XREF	CAPEC:385

XREF	CAPEC:386
XREF	CAPEC:387
XREF	CAPEC:388
XREF	CAPEC:504
XREF	CAPEC:506
XREF	CAPEC:510
XREF	CAPEC:59
XREF	CAPEC:60
XREF	CAPEC:654
XREF	CAPEC:75
XREF	CAPEC:76
XREF	CAPEC:89
XREF	DISA_STIG:APSC-DV-002560
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A4
XREF	OWASP:2021-A7
XREF	OWASP:2025-A6
XREF	OWASP:2025-A7
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-14.4.3
XREF	OWASP_ASVS:4.0.2-14.4.7
XREF	PCI_DSS:3.2-6.5
XREF	PCI_DSS:3.2-6.5.8
XREF	ISO:27001-A.10.1
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b
XREF	NIST:sp800_53-SI-10(5)

Plugin Information

Published: 2017/03/31, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/login

OUTPUT

Page https://ai.rcilab.in:8000/login has no X-Frame-Options header defined

REQUEST MADE

GET /login HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/was_404_check
```

OUTPUT

```
Page https://ai.rcilab.in:8000/was_404_check has no X-Frame-Options header defined
```

REQUEST MADE

```
GET /was_404_check HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json
```

112529 (2) - Missing 'X-Content-Type-Options' Header

Synopsis

Missing 'X-Content-Type-Options' Header

Description

The HTTP 'X-Content-Type-Options' response header prevents the browser from MIME-sniffing a response away from the declared content-type.

The server did not return a correct 'X-Content-Type-Options' header, which means that this website could be at risk of a Cross-Site Scripting (XSS) attack.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>
https://www.owasp.org/index.php/OWASP_Secure-Headers_Project#xcto

Solution

Configure your web server to include an 'X-Content-Type-Options' header with a value of 'nosniff'.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:L/SI:L/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF [CWE:693](#)
XREF WASC:Application Misconfiguration

XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:1
XREF	CAPEC:107
XREF	CAPEC:127
XREF	CAPEC:17
XREF	CAPEC:20
XREF	CAPEC:22
XREF	CAPEC:237
XREF	CAPEC:36
XREF	CAPEC:477
XREF	CAPEC:480
XREF	CAPEC:51
XREF	CAPEC:57
XREF	CAPEC:59
XREF	CAPEC:65
XREF	CAPEC:74
XREF	CAPEC:87
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2025-A6
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	PCI_DSS:3.2-2.2
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2018/11/28, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/login

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /login HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/was_404_check

OUTPUT

The scanner detected the lack of a correct X-Content-Type-Options header configuration in the target application response

REQUEST MADE

GET /was_404_check HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json

112553 (2) - Missing 'Cache-Control' Header -

Synopsis

Missing 'Cache-Control' Header

Description

The HTTP 'Cache-Control' header is used to specify directives for caching mechanisms.

The server did not return or returned an invalid 'Cache-Control' header which means page containing sensitive information (password, credit card, personal data, social security number, etc) could be stored on client side disk and then be exposed to unauthorised persons. This URL is flagged as a specific example.

See Also

[https://www.owasp.org/index.php/Testing_for_Browser_cache_weakness_\(OTG-AUTHN-006\)](https://www.owasp.org/index.php/Testing_for_Browser_cache_weakness_(OTG-AUTHN-006))
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control>

Solution

Configure your web server to include a 'Cache-Control' header with appropriate directives. If page contains sensitive information 'Cache-Control' value should be 'no-store' and 'Pragma' header value should be 'no-cache'.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.7 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:525
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)

XREF	CAPEC:37
XREF	DISA_STIG:APSC-DV-002480
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A4
XREF	OWASP:2025-A6
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-8.2.1
XREF	PCI_DSS:3.2-2.2
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2019/02/15, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/login
```

OUTPUT

```
https://ai.rcilab.in:8000/login has no Cache Control header defined.
```

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/was_404_check
```

OUTPUT

```
https://ai.rcilab.in:8000/was_404_check has no Cache Control header defined.
```

REQUEST MADE

```
GET /was_404_check HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json
```

98057 (1) - Insecure 'Access-Control-Allow-Origin' Header

Synopsis

Insecure 'Access-Control-Allow-Origin' Header

Description

Cross Origin Resource Sharing (CORS) is an HTML5 technology which gives modern web browsers the ability to bypass restrictions implemented by the Same Origin Policy.

The Same Origin Policy requires that both the JavaScript and the page are loaded from the same domain in order to allow JavaScript to interact with the page. This in turn prevents malicious JavaScript being executed when loaded from external domains.

The CORS policy allows the application to specify exceptions to the protections implemented by the browser, and enables the developer to specify allowlisted domains for which external JavaScript is permitted to execute and interact with the page.

The 'Access-Control-Allow-Origin' header is insecure when set to '*' or null, as it allows any domain to perform cross-domain requests and read responses. An attacker could abuse this configuration to retrieve private content from an application which does not use standard authentication mechanisms (for example, an Intranet allowing access from the internal network only).

See Also

https://www.owasp.org/index.php/CORS_OriginHeaderScrutiny
https://developer.mozilla.org/en-US/docs/Web/HTTP/Access_control_CORS

Solution

Unless the target application is specifically designed to serve public content to any domain, the 'Access-Control-Allow-Origin' should be configured with an allowlist including only known and trusted domains to perform cross-domain requests if needed, or should be disabled.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:16
XREF	WASC:Application Misconfiguration
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A5
XREF	OWASP:2025-A2

Plugin Information

Published: 2017/03/31, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/authenticate
```

PROOF

```
Access-Control-Allow-Origin: *
```

OUTPUT

```
Vulnerability has been detected on URL 'https://ai.rcilab.in:8000/authenticate'  
  
To confirm the presence of the vulnerability, this proof has been identified in the target response:  
  
| Access-Control-Allow-Origin: *  
  
The information used to check the vulnerability have been provided in attachment.
```

REQUEST MADE

```
POST /authenticate
```

REQUEST HEADERS

```
Content-Type: application/x-www-form-urlencoded  
Origin: https://ai.rcilab.in:8000  
Referer: https://ai.rcilab.in:8000/login  
Sec-Fetch-Dest: empty  
Sec-Fetch-Mode: cors  
Sec-Fetch-Site: same-origin  
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36  
Sec-Ch-Ua: "Chromium";v="149", "Not)A;Brand";v="24"  
Sec-Ch-Ua-Mobile: ?0  
Sec-Ch-Ua-Platform: "Linux"  
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 303 See Other  
date: Mon, 17 Aug 2026 07:00:00 GMT  
server: uvicorn  
content-length: 0  
location: /login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials  
access-control-allow-origin: *  
access-control-allow-credentials: true
```

98081 (1) - Password Field With Auto-Complete -

Synopsis

Password Field With Auto-Complete

Description

In typical form-based web applications, it is common practice for developers to allow `autocomplete` within the HTML form to improve the usability of the page. With `autocomplete` enabled (default), the browser is allowed to cache previously entered form values.

For legitimate purposes, this allows the user to quickly re-enter the same data when completing the form multiple times.

When `autocomplete` is enabled on either/both the username and password fields, this could allow a cyber-criminal with access to the victim's computer the

ability to have the victim's credentials automatically entered as the cyber-criminal visits the affected page.

Scanner has discovered that the affected page contains a form containing a password field that has not disabled `autocomplete`.

See Also

[https://www.owasp.org/index.php/Testing_for_Vulnerable_Remember_Password_\(OTG-AUTHN-005\)](https://www.owasp.org/index.php/Testing_for_Vulnerable_Remember_Password_(OTG-AUTHN-005))

Solution

The `autocomplete` value can be configured in two different locations.
The first and most secure location is to disable the `autocomplete` attribute on the `` HTML tag. This will disable `autocomplete` for all inputs within that form. An example of disabling `autocomplete` within the form tag is ``.
The second slightly less desirable option is to disable the `autocomplete` attribute for a specific `` HTML tag. While this may be the less desired solution from a security perspective, it may be preferred method for usability reasons, depending on size of the form. An example of disabling the `autocomplete` attribute within a password input tag is ``.

Risk Factor

Low

CVSS v4.0 Base Score

2.3 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:P/VC:L/VI:N/VA:N/SC:N/SI:L/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:16
XREF	WASC:Application Misconfiguration
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A5
XREF	OWASP:2025-A2
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8

Plugin Information

Published: 2017/03/31, Modified: 2022/03/03

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/login
```

INPUT TYPE

```
form
```

INPUT NAME

```
id:login-form
```

OUTPUT

```
The following form has been found to have not restricted 'password auto complete' attribute :  
<form id="login-form">  
<input type="text" id="username" name="username" required="" autofocus="">
```

```
</input>
<input type="password" id="password" name="password" required="">
</input>
<button type="submit" id="login-btn">
Login
</button>
</form>
```

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

112539 (1) - SSL/TLS Weak Cipher Suites Supported

Synopsis

SSL/TLS Weak Cipher Suites Supported

Description

The remote host supports the use of SSL/TLS ciphers that offer weak encryption (including RC4 and 3DES encryption).

See Also

<https://www.iana.org/assignments/tls-parameters/tls-parameters.xhtml>

Solution

Reconfigure the affected application, if possible to avoid the use of weak ciphers.

Risk Factor

Low

CVSS v4.0 Base Score

2.3 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:P/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.7 (CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:326
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:112
XREF	CAPEC:192

XREF	CAPEC:20
XREF	DISA_STIG:APSC-DV-002440
XREF	OWASP:2010-A7
XREF	OWASP:2013-A6
XREF	OWASP:2017-A3
XREF	OWASP:2021-A2
XREF	OWASP:2025-A4
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-9.1.2
XREF	PCI_DSS:3.2-6.5.3
XREF	PCI_DSS:3.2-6.5.4
XREF	ISO:27001-A.10.1.2
XREF	NIST:sp800_53-SC-12

Plugin Information

Published: 2019/01/21, Modified: 2022/10/07

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

Protocol	Cipher Suite Name (RFC)	Key Exchange	Strength
TLS1.2	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA	x25519	256
TLS1.2	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA	x25519	256

112551 (1) - Missing Content Security Policy -

Synopsis

Missing Content Security Policy

Description

Content Security Policy (CSP) is a web security standard that helps to mitigate attacks like cross-site scripting (XSS), clickjacking or mixed content issues. CSP provides mechanisms to websites to restrict content that browsers will be allowed to load.

No CSP header has been detected on this host. This URL is flagged as a specific example.

See Also

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>
- <https://developers.google.com/web/fundamentals/security/csp/>
- <https://content-security-policy.com/>
- <https://csp-evaluator.withgoogle.com/>

Solution

Configure Content Security Policy on your website by adding 'Content-Security-Policy' HTTP header or meta tag http-equiv='Content-Security-Policy'.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

References

XREF	CWE:1021
XREF	WASC:Application Misconfiguration
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:103
XREF	CAPEC:181
XREF	CAPEC:222
XREF	CAPEC:504
XREF	CAPEC:506
XREF	CAPEC:654
XREF	DISA_STIG:APSC-DV-002560
XREF	OWASP:2010-A6
XREF	OWASP:2013-A5
XREF	OWASP:2017-A6
XREF	OWASP:2021-A4
XREF	OWASP:2025-A6
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-14.4.3
XREF	PCI_DSS:3.2-6.5
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-CM-6b

Plugin Information

Published: 2019/02/14, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/login
```

OUTPUT

```
https://ai.rcilab.in:8000/login has no Content Security Policy defined.
```

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

113332 (1) - Login Form Cross-Site Request Forgery

-

Synopsis

Login Form Cross-Site Request Forgery

Description

Cross Site Request Forgery (CSRF) occurs when an user is tricked into clicking on a link which would automatically submit a request without the user's consent.

This can be made possible when the request does not include an anti-CSRF token, generated each time the request is visited and passed when the request is submitted, and which can be used by the web application backend to verify that the request originates from a legitimate user.

Exploiting requests vulnerable to Cross-Site Request Forgery requires different factors:

- The request must perform a sensitive action.
- The attacker must make the victim click on a link to send the request without their consent.

The exploitation of this vulnerability will in most cases have a very limited impact. However, it is possible to create complex scenarios in case the application is also vulnerable to Cross-Site Scripting.

See Also

http://en.wikipedia.org/wiki/Cross-site_request_forgery
[https://www.owasp.org/index.php/Cross-Site_Request_Forgery_\(CSRF\)](https://www.owasp.org/index.php/Cross-Site_Request_Forgery_(CSRF))
[https://www.owasp.org/index.php/Testing_for_CSRF_\(OTG-SESS-005\)](https://www.owasp.org/index.php/Testing_for_CSRF_(OTG-SESS-005))
<http://www.cgisecurity.com/csrf-faq.html>
https://www.nccgroup.trust/globalassets/our-research/us/whitepapers/csrf_paper.pdf
https://codex.wordpress.org/WordPress_Nonces
<https://www.drupal.org/docs/7/security/writing-secure-code/create-forms-in-a-safe-way-to-avoid-cross-site-request-forgeries>
https://docs.joomla.org/How_to_add_CSrf_anti-spoofing_to_forms
<https://docs.djangoproject.com/en/1.11/ref/csrf/>
https://symfony.com/doc/current/form/csrf_protection.html

Solution

Update the application by adding support of anti-CSRF tokens on this login form.
Most web frameworks provide either built-in solutions or have plugins that can be used to easily add these tokens to any form. Check the references for possible solutions provided for the most known frameworks.

Risk Factor

Low

CVSS v4.0 Base Score

2.1 (CVSS:4.0/AV:N/AC:H/AT:N/PR:N/UI:A/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N)

CVSS v3.0 Base Score

3.1 (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:N/I:L/A:N)

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:N/I:P/A:N)

References

XREF	CWE:352
XREF	WASC:Cross-Site Request Forgery
XREF	HIPAA:164.306(a)(1)
XREF	HIPAA:164.306(a)(2)
XREF	CAPEC:111
XREF	CAPEC:462
XREF	CAPEC:467
XREF	CAPEC:62
XREF	DISA_STIG:APSC-DV-002500
XREF	OWASP:2010-A5
XREF	OWASP:2013-A8
XREF	OWASP:2021-A1
XREF	OWASP:2025-A1
XREF	OWASP_API:2019-API7
XREF	OWASP_API:2023-API8
XREF	OWASP_ASVS:4.0.2-4.2.2
XREF	PCI_DSS:3.2-6.5.9
XREF	ISO:27001-A.12.6.1
XREF	ISO:27001-A.14.2.5
XREF	NIST:sp800_53-SI-10(5)

Plugin Information

Published: 2022/08/08, Modified: 2023/01/17

Instances

https://ai.rcilab.in:8000/ (tcp/8000)

URL

```
https://ai.rcilab.in:8000/login
```

PROOF

```
<form id="login-form">
<input type="text" id="username" name="username" required="" autofocus="">
</input>
<input type="password" id="password" name="password" required="">
</input>
<button type="submit" id="login-btn">
Login
</button>
</form>
```

OUTPUT

No anti-CSRF token could have been found in the login form with ID login-form.

By requesting it several times, the scanner could not find any dynamic input field that would generate a token used by the application to confirm the user intention to submit this form.

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

98618 (4) - HTTP Header Information Disclosure

Synopsis

HTTP Header Information Disclosure

Description

The HTTP headers sent by the remote web server disclose information that can aid an attacker, such as the server version and technologies used by the web server.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers>
<http://projects.webappsec.org/w/page/13246925/Fingerprinting>

Solution

Modify the HTTP headers of the web server to not disclose detailed information about the underlying web server.

Risk Factor

None

Plugin Information

Published: 2019/06/12, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/authenticate
```

OUTPUT

```
The following header information disclosures have been detected on https://ai.rcilab.in:8000/authenticate:  
  
- Server: uvicorn
```

REQUEST MADE

```
POST /authenticate
```

REQUEST HEADERS

```
Content-Type: application/x-www-form-urlencoded  
Origin: https://ai.rcilab.in:8000  
Referer: https://ai.rcilab.in:8000/login  
Sec-Fetch-Dest: empty  
Sec-Fetch-Mode: cors  
Sec-Fetch-Site: same-origin  
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36  
Sec-Ch-Ua: "Chromium";v="149", "Not)A;Brand";v="24"  
Sec-Ch-Ua-Mobile: ?0  
Sec-Ch-Ua-Platform: "Linux"  
Accept-Language: en-US,en;q=0.9
```

RESPONSE HEADERS

```
HTTP/1.1 303 See Other  
date: Mon, 17 Aug 2026 07:00:00 GMT  
server: uvicorn  
content-length: 0  
location: /login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials  
access-control-allow-origin: *  
access-control-allow-credentials: true
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
The following header information disclosures have been detected on https://ai.rcilab.in:8000/:  
  
- Server: uvicorn
```

REQUEST MADE

```
GET / HTTP/1.1
```

REQUEST HEADERS


```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 303 See Other
date: Mon, 17 Aug 2026 06:52:36 GMT
server: uvicorn
content-length: 0
location: /login
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/login
```

OUTPUT

```
The following header information disclosures have been detected on https://ai.rcilab.in:8000/login:

- Server: uvicorn
```

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/was_404_check
```

OUTPUT

```
The following header information disclosures have been detected on https://ai.rcilab.in:8000/was_404_check:

- Server: uvicorn
```

REQUEST MADE

```
GET /was_404_check HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json
```

98050 (3) - Interesting Response

Synopsis

Interesting Response

Description

The scanner identified some responses with a status code other than the usual 200 (OK), 301 (Moved Permanently), 302 (Found) and 404 (Not Found) codes. These codes can provide useful insights into the behavior of the web application and identify any unexpected responses to be addressed.

See Also

<http://www.w3.org/Protocols/rfc2616/rfc2616-sec10.html>
https://en.wikipedia.org/wiki/List_of_HTTP_status_codes

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2021/06/14

Instances

<https://ai.rcilab.in:8000/> (tcp/8000)
URL

```
https://ai.rcilab.in:8000/authenticate
```

PROOF

```
HTTP/1.1 422 Unprocessable Entity
```

OUTPUT

A response has been received with a response code '422' which may require further investigation to verify if this response is due to an abnormal behavior of the target.

The response has been triggered by an HTTP POST request made on the URL 'https://ai.rcilab.in:8000/authenticate'.

REQUEST MADE

```
POST /authenticate HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
```

```
Accept-Language: en-US,en;q=0.5
Content-Length: 0
Content-Type: application/x-www-form-urlencoded
```

RESPONSE HEADERS

```
HTTP/1.1 422 Unprocessable Entity
date: Mon, 17 Aug 2026 07:03:18 GMT
server: uvicorn
content-length: 174
content-type: application/json
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/login
```

PROOF

```
HTTP/1.1 400 Bad Request
```

OUTPUT

A response has been received with a response code '400' which may require further investigation to verify if this response is due to an abnormal behavior of the target.

The response has been triggered by an HTTP GET request made on the URL 'https://ai.rcilab.in:8000/login'.

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Content-Length: x
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 400 Bad Request
content-type: text/plain; charset=utf-8
connection: close
Transfer-Encoding: chunked
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

PROOF

```
HTTP/1.1 405 Method Not Allowed
```

OUTPUT

A response has been received with a response code '405' which may require further investigation to verify if this response is due to an abnormal behavior of the target.

The response has been triggered by an HTTP TRACE request made on the URL 'https://ai.rcilab.in:8000/'.

REQUEST MADE

TRACE / HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
X-Tenable-Wasscan-Trace: 1
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 405 Method Not Allowed
date: Mon, 17 Aug 2026 06:56:20 GMT
server: uvicorn
allow: GET
content-length: 31
content-type: application/json

98148 (2) - Form Detected -

Synopsis

Form Detected

Description

The scanner has detected the presence of a form during the crawling of the target web application. Details about the form are provided in the plugin output.

Risk Factor

None

Plugin Information

Published: 2021/10/21, Modified: 2021/10/21

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/login

INPUT TYPE

form

INPUT NAME

id:login-form

OUTPUT

A form with identifier id `login-form` has been detected on the following URL https://ai.rcilab.in:8000/login with input fields :
- username (text)
- password (password)
- login-btn (submit)

This form is submitted by using the following action : https://ai.rcilab.in:8000/login

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

https://ai.rcilab.in:8000/ (tcp/8000)

URL

```
https://ai.rcilab.in:8000/login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials
```

INPUT TYPE

form

INPUT NAME

combined:get::https://ai.rcilab.in:8000/login

OUTPUT

A form with no identifier has been detected on the following URL https://ai.rcilab.in:8000/login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials with no input fields

This form is submitted by using the following action : https://ai.rcilab.in:8000/login

REQUEST MADE

```
GET /login?error=LDAP%20Error%3A%20automatic%20bind%20not%20successful%20-%20invalidCredentials
```

REQUEST HEADERS

```
Referer: https://ai.rcilab.in:8000/login
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Sec-Ch-Ua: "Chromium";v="149", "Not)A;Brand";v="24"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 07:00:00 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

Synopsis

Missing Permissions Policy

Description

Permissions Policy provides mechanisms to websites to restrict the use of browser features in its own frame and in iframes that it embeds.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Feature-Policy>
<https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/>

Solution

Configure Permissions Policy on your website by adding 'Permissions-Policy' HTTP header.

Risk Factor

None

Plugin Information

Published: 2019/03/27, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/login

OUTPUT

No Permissions-Policy headers were found on https://ai.rcilab.in:8000/login

REQUEST MADE

GET /login HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/was_404_check

OUTPUT

No Permissions-Policy headers were found on https://ai.rcilab.in:8000/was_404_check

REQUEST MADE

```
GET /was_404_check HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json
```

98527 (2) - Missing Referrer Policy -

Synopsis

Missing Referrer Policy

Description

Referrer Policy provides mechanisms to websites to restrict referrer information (sent in the referer header) that browsers will be allowed to add.

No Referrer Policy header or metatag configuration has been detected.

See Also

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>

Solution

Configure Referrer Policy on your website by adding 'Referrer-Policy' HTTP header or meta tag referrer in HTML.

Risk Factor

None

Plugin Information

Published: 2019/04/02, Modified: 2024/03/25

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/login
```

OUTPUT

```
No Referrer-Policy headers or body meta tags were found on https://ai.rcilab.in:8000/login
```

REQUEST MADE

```
GET /login HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:55 GMT
server: uvicorn
content-length: 6326
content-type: text/html; charset=utf-8
```

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/was_404_check
```

OUTPUT

```
No Referrer-Policy headers or body meta tags were found on https://ai.rcilab.in:8000/was_404_check
```

REQUEST MADE

```
GET /was_404_check HTTP/1.1
```

REQUEST HEADERS

```
Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5
```

RESPONSE HEADERS

```
HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 07:10:26 GMT
server: uvicorn
content-length: 22
content-type: application/json
```

98000 (1) - Scan Information -

Synopsis

Scan Information

Description

Provides scan information and statistics of plugins run.

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2026/04/30

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

```
Engine Version 2.111.8-2273
Plugins Version 202608110549
Scan ID 0f8554be-4617-4fe3-b8ed-803bb2a3919c
Scanner Public IP N/A

Start Time 2026-08-17 12:20:51 +0000
Duration 00:18:06

Requests 18482
Crawler Requests 34
Requests/s 25.4561
Mean Response Time 0.0922s

Bandwidth Usage
- Data to Target 11.5 MB
- Data from Target 72.6 MB

Timeouts Encountered
Network Timeouts 0
Browser Timeouts 0

Browser Respawns 0

HTTP Protocols Detected
- HTTPs

Authentication Identified
- None

Plugins
- 1052 have been included per scan policy
- 715 have been started based on target information collected

List of plugins is available in 'plugins.csv' attachment.

Settings used to conduct this scan are available in 'configuration.csv' attachment.
```

98009 (1) - Web Application Sitemap

Synopsis

Web Application Sitemap

Description

Publishes the sitemap of the web application as seen by the scan.

The list of all URLs that have been detected during the scan are available as an attachment. For each URL in the sitemap, the following information is provided:

- The first time the URL is detected - The logic used to detect the URL. This information may be found by: crawling rendering the page by a specific plugin - The parent URL requested to detect the URL - If the URL has been requested at least once, information about the response - Whether or not the URL has been queued for audit - If the URL has not been queued for audit, the reason why the URL does not need an audit - Whether or not the URL has been effectively audited - If the URL has not been effectively audited, the reason that the scanner was unable to audit the URL

Reasons for not adding a URL to the audit queue are as follows:

- not_in_domain: The domain of the URL does not match main target URL - scope_configuration: The URL does not match scope include list scan settings - directory_depth: The number of directories in the URL path exceeds the scan configuration setting - exclude_file_extension: The URL file extension matched one entry of the file extension blacklist setting - exclude_path_patterns: The URL matched one entry of the URL exclusion blacklist setting - redundant_path: The number of URLs to be audited with the same path and query string parameters has been reached - request_redirect_limit: The number of HTTP redirects allowed per scan configuration setting has been reached - queue_full: The number of URLs to audit has been reached

If a scan fails to audit a URL that has been queued for audit, reasons for the failure are as follows:

- timeout: The request timed out when trying to retrieve URL contents - filesize_exceeded: URL response exceeded file size limit defined in the scan configuration - scan_timelimit_reached: The URL couldn't be audited before the scan time limit - user_abort: The user stopped the scan before the URL could be audited

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2023/11/17

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
The scan has discovered 5 distinct URLs.

The following is a breakdown of which URLs were audited:

- 5 effectively audited

For URLs we received responses for, here is a distribution of the content type headers:

- 2 application/json
- 2 text/html; charset=utf-8

Response times ranged between 0.002824s and 0.032365s.

You can access the complete list of URLs with the information collected by the scan as an attachment to this plugin.
```

98047 (1) - Allowed HTTP Methods -

Synopsis

Allowed HTTP Methods

Description

There are a number of HTTP methods that can be used on a webserver ('OPTIONS', 'HEAD', 'GET', 'POST', 'PUT', 'DELETE' etc.). Each of these methods perform a different function and each have an associated level of risk when their use is permitted on the webserver.

By sending an HTTP OPTIONS request and a direct HTTP request for each method, the scanner discovered the methods that are allowed by the server.

See Also

<http://httpd.apache.org/docs/2.2/mod/core.html#limitexcept>

Solution

It is recommended that a whitelisting approach be taken to explicitly permit only the HTTP methods required by the application and block all others.

Risk Factor

None

Plugin Information

Published: 2017/03/31, Modified: 2024/02/27

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

The scanner was able to identify several HTTP methods that can be used for one or several URLs. The results are available as attachments.

98059 (1) - Technologies Detected

Synopsis

Technologies Detected

Description

This is an informational plugin to inform the user what technologies the framework has detected on the target application, which can then be examined and checked for known vulnerable software versions

Solution

Only use components that do not have known vulnerabilities, only use components that when combined to not introduce a security vulnerability, and ensure that a misconfiguration does not cause any vulnerabilities

Risk Factor

None

Plugin Information

Published: 2017/12/06, Modified: 2023/11/17

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

The framework has detected the following technologies in the target application:

- Swagger UI (version unknown)

98136 (1) - Target Information

Synopsis

Target Information

Description

Publishes the target information of the starting url as evaluated by the scan.

Risk Factor

None

Plugin Information

Published: 2017/07/27, Modified: 2024/04/26

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

Access to URL 'https://ai.rcilab.in:8000/' has been confirmed.

Target Information

Domain Name : ai.rcilab.in
IP Address : 172.27.30.222

Response Information

Status Code : 303
Return Code : ok
Return Message: No error
Response Time : 0.021497s
Response Size : 117 bytes
Content-Type : -

REQUEST MADE

GET / HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 303 See Other
date: Mon, 17 Aug 2026 06:52:35 GMT
server: uvicorn
content-length: 0
location: /login

98138 (1) - Screenshot

Synopsis

Screenshot

Description

Screenshot of the target web page, see attached image. This screenshot should show you the target page we are launching the scan against. If the image is not of the intended target page, please check the provided url in the scan configuration.

Risk Factor

None

Plugin Information

Published: 2018/01/23, Modified: 2018/02/14

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

WAS Scanner has taken a screenshot of the page at url 'https://ai.rcilab.in:8000/' with dimensions 1600x1200.
Please see the attachment for the screenshot image.

98772 (1) - Fetch/XHR Detected

Synopsis

Fetch/XHR Detected

Description

The scan detected that the web application makes requests that appear to be using Fetch or XMLHttpRequests (XHRs) to communicate with a backend API server. Fetchs/XHRs allow retrieval of data from an API without triggering a page reload, making them especially useful for Single Page Applications.

See Also

<https://developer.mozilla.org/en-US/docs/Web/API/XMLHttpRequest>

Risk Factor

None

Plugin Information

Published: 2019/11/14, Modified: 2023/11/17

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

The scan detected 2 unique Fetch Requests. Here is the distribution of MIME types used by the detected requests:

- 1 as "text/html"
- 1 with no specified or detected MIME type

112491 (1) - SSL/TLS Certificate Information

Synopsis

SSL/TLS Certificate Information

Description

This plugin displays information about the X.509 certificate extracted from the HTTPS connection.

Risk Factor

None

Plugin Information

Published: 2018/10/03, Modified: 2023/05/05

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
Certificate 1
-----
Common Name: *.rcilab.in
Alternative Names: *.rcilab.in rcilab.in
Issuer: Sectigo Limited
Valid from: 2025-12-07 00:00:00 UTC
Valid until: 2027-01-07 23:59:59 UTC (expires in 4 months, 3 weeks)
Validity Period: 396 days
Key: RSA 2048-bit
Signature: sha256WithRSAEncryption
```

Certificate 2

Common Name: sectigo public server authentication ca dv r36
Issuer: Sectigo Limited
Valid from: 2021-03-22 00:00:00 UTC
Valid until: 2036-03-21 23:59:59 UTC (expires in 9 years, 7 months, 4 days)
Validity Period: 5478 days
Key: RSA 3072-bit
Signature: sha384WithRSAEncryption

Certificate 3

Common Name: sectigo public server authentication root r46
Issuer: The USERTRUST Network
Valid from: 2021-03-22 00:00:00 UTC
Valid until: 2038-01-18 23:59:59 UTC (expires in 11 years, 5 months, 2 days)
Validity Period: 6146 days
Key: RSA 4096-bit
Signature: sha384WithRSAEncryption

Certificate 4

Common Name: usertrust rsa certification authority
Issuer: The USERTRUST Network
Valid from: 2010-02-01 00:00:00 UTC
Valid until: 2038-01-18 23:59:59 UTC (expires in 11 years, 5 months, 2 days)
Validity Period: 10213 days
Key: RSA 4096-bit
Signature: sha384WithRSAEncryption

112530 (1) - SSL/TLS Versions Supported

Synopsis

SSL/TLS Versions Supported

Description

This plugin displays information about the SSL/TLS versions supported by remote server for HTTPS connection.

See Also

<https://www.iana.org/assignments/tls-parameters/tls-parameters.xhtml>

Risk Factor

None

Plugin Information

Published: 2018/10/03, Modified: 2020/10/02

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

Protocol Supported

SSL 2.0 No
SSL 3.0 No
TLS 1.0 No
TLS 1.1 No
TLS 1.2 Yes
TLS 1.3 Yes

112598 (1) - SSL/TLS Server Cipher Suite Preference

Synopsis

SSL/TLS Server Cipher Suite Preference

Description

The remote server is configured with a SSL/TLS cipher suite preference list used to determine the cipher suite during the negotiation with the client.

See Also

https://wiki.mozilla.org/Security/Server_Side_TLS
<http://www.exploresecurity.com/testing-for-cipher-suite-preference/>

Risk Factor

None

Plugin Information

Published: 2020/09/24, Modified: 2020/09/24

Instances

<https://ai.rcilab.in:8000/> (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
The scanner detected that the remote host is configured with cipher suite preference on the following protocol(s):

TLS v1.3
-----
TLS_AES_256_GCM_SHA384
TLS_CHACHA20_POLY1305_SHA256
TLS_AES_128_GCM_SHA256

TLS v1.2
-----
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA
```

112613 (1) - Allowed HTTP Versions

Synopsis

Allowed HTTP Versions

Description

The Hypertext Transfer Protocol (HTTP) is the underlying protocol of the World Wide Web. Since its first release, HTTP has evolved to support modern web usages and currently exists in three versions:

- HTTP/1.0
- HTTP/1.1
- HTTP/2

The scanner identified the supported versions of the HTTP protocol on the target web application.

See Also

https://developer.mozilla.org/en-US/docs/Web/HTTP/Basics_of_HTTP/Evolution_of_HTTP

Risk Factor

None

Plugin Information

Published: 2020/10/13, Modified: 2023/01/17

Instances

<https://ai.rcilab.in:8000/> (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

The scanner detected the following HTTP versions on the target application :

- HTTP/1.1

The list of requests and responses observed is provided in attachment.

112615 (1) - OpenAPI File Detected

Synopsis

OpenAPI File Detected

Description

An OpenAPI configuration file has been detected and is available as an attachment below. OpenAPI is a specification that helps with documentation and consumption of REST APIs and may also be used to configure API scanning.

See Also

<https://oai.github.io/Documentation/>
<https://swagger.io/docs/specification/>
<https://github.com/OAI/OpenAPI-Specification>

Risk Factor

None

Plugin Information

Published: 2020/10/20, Modified: 2024/01/08

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/openapi.json

OUTPUT

The scanner was able to detect a Swagger or OpenAPI definition file on https://ai.rcilab.in:8000/openapi.json. The file is available in attachments.

REQUEST MADE

GET /openapi.json HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 200 OK
date: Mon, 17 Aug 2026 06:59:42 GMT
server: uvicorn
content-length: 17899
content-type: application/json

112616 (1) - API Detected

Synopsis

API Detected

Description

The scan detected that some XHR requests seem to call an API. The scanner generated an OpenAPI file based on the observed requests and attached it to the plugin output. This OpenAPI file can then be used to run a scan against the API with WAS API Scanning.

Risk Factor

None

Plugin Information

Published: 2020/10/21, Modified: 2020/10/21

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
API endpoints have been detected for the following host(s):  
- https://ai.rcilab.in:8000
```

112723 (1) - Security.txt File Not Detected

Synopsis

Security.txt File Not Detected

Description

A Security.txt file has not been detected on the target.

When security risks in web services are discovered by independent security researchers, this file defines the channels to disclose them properly & enables 3rd party researchers to disclose issues securely in a manner defined by the organization.

Organizations should consider creating a security.txt file containing contact and other information in the defined format and place it under the .well-known directory of the server.

See Also

<https://securitytxt.org/>
<https://tools.ietf.org/html/draft-foudil-securitytxt-11>

Risk Factor

None

Plugin Information

Published: 2021/03/17, Modified: 2021/03/17

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/.well-known/security.txt
```

OUTPUT

No or a malformed security.txt was found at 'https://ai.rcilab.in:8000/.well-known/security.txt'.

REQUEST MADE

GET /.well-known/security.txt HTTP/1.1

REQUEST HEADERS

Host: ai.rcilab.in:8000
Accept-Encoding: gzip, deflate, br
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/149.0.7797.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Language: en-US,en;q=0.5

RESPONSE HEADERS

HTTP/1.1 404 Not Found
date: Mon, 17 Aug 2026 06:52:38 GMT
server: uvicorn
content-length: 22
content-type: application/json

113045 (1) - SSL/TLS Certificate Contains Wildcard Entries

Synopsis

SSL/TLS Certificate Contains Wildcard Entries

Description

The remote server presents an SSL/TLS certificate with wildcard entries. The use of a wildcard character in a entry permits a certificate to cover a number of subdomains of a domain.

Risk Factor

None

Plugin Information

Published: 2021/11/10, Modified: 2021/11/10

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

https://ai.rcilab.in:8000/

OUTPUT

A wildcard symbol (*) has been detected in the following certificate entries:
Certificate Common Name: *.rcilab.in
Certificate Subject Alternative Names:
- *.rcilab.in

113393 (1) - Performance Telemetry

Synopsis

Performance Telemetry

Description

This finding provides information to assist in scan performance tuning.

Risk Factor

None

Plugin Information

Published: 2022/10/17, Modified: 2024/10/03

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
Three attachments are included in this finding to assist in performance tuning of your scan:
-pages_telemetry.csv: Scan statistics organized by page
-plugins_telemetry.csv: Scan statistics organized by plugin
-time_telemetry.csv: Chronological scan statistics
```

115491 (1) - SSL/TLS Cipher Suites Supported -

Synopsis

SSL/TLS Cipher Suites Supported

Description

This plugin displays supported SSL/TLS cipher suites.

See Also

<https://www.iana.org/assignments/tls-parameters/tls-parameters.xhtml>

Risk Factor

None

Plugin Information

Published: 2019/01/09, Modified: 2022/10/07

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
URL

```
https://ai.rcilab.in:8000/
```

OUTPUT

```
Protocol Cipher Suite Name (RFC) Key Exchange Strength
-----
TLS1.2 TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA x25519 256
TLS1.2 TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA x25519 256
TLS1.3 TLS_AES_256_GCM_SHA384 x25519 256
TLS1.3 TLS_CHACHA20_POLY1305_SHA256 x25519 256
TLS1.3 TLS_AES_128_GCM_SHA256 x25519 256
```

172036 (1) - Web Application Scanner -

Synopsis

Discovers vulnerabilities in Web applications.

Description

This plugin provides vulnerability detections in Web applications and Web site files.

See Also

Solution

Vulnerabilities resolution depends on WAS results.

Risk Factor

None

Plugin Information

Published: 2023/08/07, Modified: 2026/08/10

Instances

https://ai.rcilab.in:8000/ (tcp/8000)
OUTPUT

Scan completed. Please see the attachments for more information.